CALMGuard

From Architecture-as-Code to Continuous Compliance, Automatically

"Describe your architecture in CALM. Let AI agents tell you where you're exposed."

Initcron Systems & OpsFlow LLC | DTCC/FINOS Innovate.DTCC AI Hackathon | Feb 27, 2026

The Team

Track: IT Innovation — Multi-Agent Development, DevSecOps, Advanced Security

Gourav Shah

Co-Founder, Product & Tech

OpsFlow LLC

Anoop Mehendale

Co-Founder, Business

OpsFlow LLC

Built on FINOS CALM — the open standard created at Morgan Stanley

The Problem

$6.6B

regulatory fines globally (2024)

68%

compliance failures from architecture gaps

2-4 wks

for a single manual compliance review

Manual

Architects review diagrams against checklists by hand

Reactive

Gaps found during audits, not during design

Siloed

Architecture, compliance, and CI/CD disconnected

Stale

Architecture evolves, compliance report doesn't

CALM makes architecture machine-readable. What's missing: intelligent automation that connects it to compliance + DevSecOps.

SOX — Sarbanes-Oxley Act

Internal controls over financial reporting (Section 404 & 302)

What CALMGuard Detects

- Missing access controls on financial data nodes
- Absent audit logging for transaction systems
- Lack of segregation of duties in architecture
- No trust boundaries between financial reporting and other systems
- Missing encryption on data at rest for financial records

What CALMGuard Generates

- CI/CD pipelines with change approval gates
- Audit trail enforcement in deployment configs
- Control-to-requirement mapping (SOX 404)
- Risk scores weighted by financial data exposure
- Remediation PRs adding missing CALM controls

KEY VALUE: Shifts SOX compliance from annual audit scrambles to continuous evidence generation. Every architecture change in Git triggers re-analysis — auditors get a continuous trail, not a point-in-time snapshot.

PCI-DSS — Payment Card Industry Data Security Standard

12 requirements across 6 categories — many observable at the architecture level

Req 1

Network Segmentation

Validates trust boundaries isolate cardholder data environments

Req 3-4

Encryption

Checks TLS/mTLS on relationships & encryption controls on data nodes

Req 7

Access Control

Verifies least-privilege access patterns in architecture definition

Req 8

Authentication

Detects missing auth mechanisms on service-to-service connections

Req 10

Logging & Monitoring

Confirms audit logging nodes connected to security-sensitive components

Req 11

Security Testing

Generates SAST/DAST pipeline configs specific to payment components

KEY VALUE: Architecture-aware pipeline generation means a payment gateway gets PCI-specific scanning rules — not generic templates. Different architecture topology = different security pipeline.

FINOS-CCC — Common Cloud Controls

Shared cloud security controls for financial institutions — same FINOS ecosystem as CALM

CCC Control Categories Mapped

- Data residency & sovereignty for cloud nodes
- Encryption at rest and in transit
- Identity & access management (IAM)
- Network isolation & segmentation
- Logging, monitoring & observability
- Incident response mechanisms

FINOS Ecosystem Synergy

- CALM + CCC live in same FINOS ecosystem
- SKILL.md compliance files are community-contributed
- 18.6 KB of CCC-specific knowledge in Mapper agent
- As CCC evolves, SKILL.md updates flow to all deployments
- Validates FINOS vision: machine-readable architecture → actionable compliance

KEY VALUE: CALMGuard proves CALM is more than documentation — it's the foundation for automated cloud compliance. This increases CALM adoption by demonstrating tangible ROI across the FINOS community.

NIST-CSF — Cybersecurity Framework 2.0

Six core functions mapped to CALMGuard's AI agent capabilities

GOVERN — Strong

Risk Scorer

Aggregated risk posture with severity-weighted findings

IDENTIFY — Strong

Architecture Analyzer

Automated asset inventory from CALM nodes & data flows

PROTECT — Strong

Compliance Mapper

Access control, data security, platform security checks

DETECT — Strong

Pipeline Generator

Scanning & monitoring configs in generated CI/CD

RESPOND — Partial

Compliance Mapper

Checks for incident response mechanisms in architecture

RECOVER — Partial

Architecture Analyzer

Validates DR nodes & backup relationships exist

KEY VALUE: CALM definitions are a machine-readable asset inventory — exactly what NIST CSF "Identify" requires. CALMGuard adds the intelligence layer mapping that inventory to NIST control categories.

The Cross-Framework Advantage

Every framework asks the same architecture-level questions. CALMGuard answers all four at once.

Architecture Concern	SOX	PCI-DSS	CCC	NIST
Data encryption (at rest & in transit)	✓	✓	✓	✓
Access controls & least privilege	✓	✓	✓	✓
Audit logging & monitoring	✓	✓	✓	✓
Trust boundary segmentation	✓	✓	✓	✓
Change management controls	✓	—	✓	✓
Network isolation	—	✓	✓	✓
Incident response mechanisms	—	—	✓	✓

1
CALM upload

4
frameworks analyzed

30s
total analysis time

90+ KB
compliance knowledge

Where existing tools fall short

SonarQube/Snyke

Code Scanners

Analyze code — not architecture topology

RegScale, Archer

GRC platforms

Track compliance — but can't read CALM definitions

CALM CLI

validates schemas — it doesn't analyze compliance posture

No tool connects architecture-as-code → compliance intelligence → CI/CD DevSecOps enforcement

CALMGuard

The AI Agent Squad

4 specialized agents — parallel + sequential orchestration — all output schema-validated via Zod

Architecture Analyzer

Patterns, anti-patterns, trust boundaries

Output:

Severity-scored findings

Compliance Mapper

Maps to SOX, PCI DSS, NIST, FINOS CCC

Output:

Gap analysis + evidence

Pipeline Generator

Security-hardened CI/CD from architecture

Output:

GitHub Actions + configs

Risk Scorer

Aggregates findings into weighted risk score

Output:

Score 0-100, heat map

Phase 1: Parallel

Phase 2: Sequential

All agents stream results in real-time via SSE to an interactive React Flow + Recharts dashboard

CALMGuard: How It Works

CALM-native continuous compliance DevSecOps platform

1

Connect

Git Repo +
CALM Path

2

Analyze

AI Agent Squad
Scores & Maps

3

Act

Pipelines +
Compliance Report

4

PR

GitOps PRs with
Remediation Code

What no existing tool does: CALM CLI validates schemas. Tetrate visualizes graphs. RegScale tracks compliance. SonarQube scans code. **None of them read CALM and produce compliance intelligence. CALMGuard is the first.**

Live Demo

Watch CALMGuard analyze a Payment Gateway architecture in real-time

1. Select Payment Gateway demo architecture
2. Launch 6 AI agents — watch them stream findings live
3. Review compliance scores, risk heat map, framework breakdown
4. View generated CI/CD pipeline + security configs
5. Connect repo → generate GitOps PR with remediation

Under the Hood

Tech Stack

Framework	Next.js 15 (App Router)
Language	TypeScript (strict mode)
AI SDK	Vercel AI SDK v6
LLM	Gemini / Claude / GPT / Grok
CALM	@finos/calm-cli v1.33
Viz	React Flow + Recharts + Shiki
State	Zustand v5 + SSE streaming
UI	shadcn/ui + Tailwind CSS 4
Validation	Zod v3.24 (every boundary)
CI/CD	GitHub Actions + Semgrep + CodeQL

Data Flow

Browser (React Flow + Recharts + shadcn/ui)

▼

Zustand Store + SSE Hook

▼

Next.js API Routes

▼

Agent Orchestrator (Phase 1 || Phase 2)

▼

Vercel AI SDK (generateObject + Zod)

▼

LLM Providers + 90KB Compliance Skills

▼

GitHub API (GitOps PR Generation)

GitOps PR Generation

From analysis to action — automated Pull Requests for safe, reviewable remediation

How It Works

1. **Connect Repository**
   Accept Git repo URL + path to CALM architecture file
2. **Analyze Architecture**
   Full AI agent squad analysis on the CALM definition
3. **Generate Pipeline PR**
   Branch, commit GitHub Actions + SAST/DAST + IaC — open PR
4. **Generate Remediation PR**
   Modify CALM JSON: add missing controls, fix gaps — separate PR

Why It's a Game-Changer

Analysis tool → Action tool
You don't just get a report — you get a PR ready for review.

Safe by design (GitOps)
Never pushes to main. Opens PRs for human review only.

Production-viable demo
"Watch us connect a repo, analyze it, and generate a PR — live."

No existing tool does this
First tool to go from CALM architecture to compliance PRs.

Impact & Vision

Today

- Compliance review: weeks → minutes
- Continuous posture, not point-in-time snapshots
- GitOps PRs — safe, reviewable remediation
- Architecture-aware CI/CD pipelines

Industry Collaboration

- Built on FINOS CALM (Morgan Stanley, 1,400+ deployments)
- Multi-org team, Apache 2.0 open source
- Shareable SKILL.md compliance knowledge base
- Multi-provider LLM: no vendor lock-in

Enterprise Vision: Edge Intelligence

Self-Learning

Explore Self Optimising Neural Architectures
GNN refines every query
Vector DB + LoRA + EWC++

Air-Gapped Security

100% local LLM (Ollama/vLLM)
Cognitive containers (.rvf)

Edge Intelligence

Runs on edge devices
Zero cloud dependency
Zero-trust runtime security

Roadmap

Phase 1

NOW

Hackathon Prototype

Q1 2026

- Multi version CALM parser (1.0, 1.1, 1.2)
- 6 AI agents + SSE streaming
- 5 compliance frameworks
- GitOps PR generation
- DevSecOps Pipeline generation + IaaC demo mode

Phase 2

MVP

Q2-Q3 2026

- Intelligent DevSecOps Pipelines
- Compliant Infra as Code
- Runtime Drift Detection (CALM vs Actual Infra)
- Pre-Deployment Validation
- CALMGuard as a Service (MCP/ API)
- Persistent Intelligence

Phase 3

Enterprise: Edge Intelligence

Q4 2026+

- Self-learning GNN + vector DB
- Air-gapped / local LLMs
- Multi Tenant Enterprise Deployments
- Global Learning Network

Roadmap

Phase 1

Compliant Architecture

Convert this into a Continuous Compliance System and provide it is as a MCP Server.

Phase 2

Compliant Infra / DevSecOps

Build Continuous Infra Compliance & DevSecOps Pipelines

Phase 3

Enterprise: Edge Intelligence

Build for Enterprises

Idea is to build something we are proud of, open source it. Then **Let the users decide the Roadmap. Adapt and Iterate to Enterprise Vision.**

CALMGuard

From Architecture-as-Code to Continuous Compliance

Automatically.

6 AI Agents

Parallel analysis

5 Frameworks

SOX, PCI, NIST, CCC

Gitops PR

Safe remediation

Self Learning

Learning and Optimising Skill

OpsFlow LLC | Gourav Shah & Anoop Mehendale

STAY CALM

STAY COMPLIANT

Initcron Systems & OpsFlow LLC | Gourav Shah & Anoop Mehendale | gs@initcron.org

CALMGuard

Initcron Systems & OpsFlow LLC | Gourav Shah & Anoop Mehendale | gs@initcron.org